SCM Custom Fixlet Developers Guide

Version: 0.03 2012-03-13

Status: DRAFT - Use at your own risk

Author: Jeff Saxton <jsaxton@us.ibm.com>

SCOPE:

This document is an introduction to creating custom SCM content that will work with TEM TEMA (Formerly DSS/SCA).

This document does not currently cover how to introduce parameters into your Fixlets, this is a feature provided in the TEM content however it is assumed that since you are developing custom Fixlets that this functionality is not a core requirement, A follow up document may be produced to cover the addition of this functionality if there is sufficient demand.

This guide does not cover the various options for NLS. If there is sufficient demand this information may be provided later in a follow up document.

This guide assumes that you are interested in adding custom content to an SCM site provided by TEM, creation of a "stand-alone" SCM site is beyond the scope of this documentation.

Developing custom Unix SCM content using this methodology requires the use of non-superseded sites, these non-superseded sites contain the correct infrastructure to support this type of custom content creation. Windows content developed with this methodology does not have this constraint.

Audience:

Professional Services Employees that must create SCM Content that is not covered in the TEM supplied content.

Business Partners that must create SCM content

Customers that wish to create custom SCM content.

Prerequisites:

Working TEM deployment

License for TEM SCM content

Understanding of TEM SCM Workflow

Working TEMA deployment

Basic understanding of XML and JSON

Bourne shell scripting ability (Required to create Unix content)

Knowledge of the TEM Relevance(tm) Language

Change history:

2012-03-13

Changed Source and SourceSeverity items in Fixlet XML from optional to required.

There are three TEM components that work in conjunction to report the compliance status:

Fixlet: Audits status of a check and what remediation may be taken (remediation is optional)

Analysis: Returns the actual value of the item being audited (optional)

Applicability Fixlet: How to scope the check in SCA to a particular operating system or other condition (generally it is possible to use an Applicability Fixlet from a TEM supplied content site)

An SCM Fixlet consists of the following XML elements:

Title (required)

Description (required)

Relevance (one or more Typically two for SCM)

Category (optional)

Source (required)

SourceReleaseDate (optional)

SourceSeverity (required)

SourceID (required)

x-fixlet-scm-control (required)

x-fixlet-scm-metadata (required)

x-fixlet-sentinel-idref (required)

x-fixlet-scm-id (required)

x-fixlet-scm-os (required)

x-fixlet-scm-control-id (required)

Action (optional)

x-fixlet-detect-script0-N (required, Unix only)

x-fixlet-remediate-script0-N (optional, Unix only)

SCM Fixlet components:

Title: A string that defines the title of the Fixlet. This appears in the "Name" field in the TEM console.

Description: HTML markup that displays in the body of the Fixlet.

Relevance: Typically there are two Relevance fields. The first constrains the Fixlet to a particular operating system and minimum TEM client version and the second implements the compliance check. In the case of Unix SCM a shell script is run to determine the compliance status which creates a ".results" file that the relevance reads.

Category: A String that defines the Category of the check i.e. Password Controls, File Permissions, ... This string displays in the "Category" field in the TEM console.

Source: This is a string that identifies the guidance document the check was derived from, i.e. Custom IT Policy v1.0

SourceReleaseDate: This is a date if the format of YYYY-MM-DD which identifies the date the guidance document (see above) was released.

SourceSeverity: This is a string that describes the "severity" of the check i.e: "minor", "severe", ...

SourceID: This is a string that identifies the specific section of the guidance that this fixlet fulfills i.e.: 1.2.3, GEN1234. This is used as the basename of the detect/remediate scripts in the Unix content.

x-fixlet-scm-control: This legacy MIME field is a string that identifies the Fixlet in WebReports. The best practice is currently to make this the same value as the SourceID field. This is also used in the Legacy 'SCM Exception Management' dashboard in the SCM Reporting site.

x-fixlet-scm-metadata: This MIME field is a JSON serialized data structure that is used by TEMA, a separate section of this document is dedicated to documenting this.

x-fixlet-sentinel-idref: This MIME field is a string that references the x-fixlet-sentinel-id MIME field in the applicability Fixlet and is used by TEMA to determine the applicability of the Fixlet for a particular constraint defined by the Applicability Fixlet.

x-fixlet-scm-id: This MIME field contains a string that uniquely identifies this Fixlet.

x-fixlet-scm-os: This Legacy MIME field is a string that identifies the operating system that this Fixlet applies to. Some examples are "AIX 6.1" "Linux 5",... This field is used by the Legacy 'Security Configuration Management' Dashboard in the SCM Reporting site.

x-fixlet-scm-control-id: This Legacy MIME field is a string that identifies this check to WebReports. The current best practice it to use the same value as in the SourceID field.

Action (optional): This field contains the ActionScript that will be executed to remediate the condition detected by the Fixlet.

x-fixlet-detect-script0-N (Unix only): This MIME field contains the base64 encoded shell script to run to audit the desired condition. Because of some operating system platform limitations each "chunk" i.e. x-fixlet-detect-script0, x-fixlet-detect-script1 the base64 encoded shell script is broken down into "chunks" less than 2800 bytes. There is a separate section documenting the requirement for the encoded shell script.

x-fixlet-remediate-script0-N (optional, Unix only): This MIME field contains the base64 encoded shell script to run to remediate the condition detected by this Fixlet. Because of some operating system platform limitations each "chunk" i.e. x-fixlet-remediate-script0, x-fixlet-remediate-script1 the base64 encoded shell script is broken down into "chunks" less than 2800 bytes. There is a separate section documenting the requirement for the encoded shell script.

An SCM Analysis consists of the following XML elements:

Title (required)

Description (required)

Relevance (required)

x-fixlet-scm-analysis-id (required)

x-fixlet-scm-metadata (required)

Property (required, one or more, typically one for SCM)

SCM Analysis components

Title: A string that defines the title of the Analysis. This appears in the "Name" field in the TEM console.

Description: HTML markup that displays in the body of the Analysis.

Relevance: This field is a relevance statement constrains the Fixlet to a particular operating system and minimum TEM client version.

x-fixlet-scm-analysis-id: This is a string that uniquely identifies this analysis. It is referenced by a component in the JSON serialized data structure contained in the x-fixlet-scm-metadata MIME field of the associated Fixlet.

x-fixlet-scm-metadata: This field is a JSON serialized data structure that allows you to specify the data type and a short description of the value to be displayed as the Measured Value in TEMA. NOTE: TEMA currently has limited functionality in this area.

Property: This field contains the Name of the analysis property as it appears in the TEM console, the index (1-N) of the property in case of multiple properties (note that currently we only use a single property per analysis), the EvaluationPeriod that constrains the analysis from re sampling the endpoint too frequently and a Relevance statement that returns the actual value of the item being tested for compliance by the associated Fixlet. In the case of SCM Unix content the shell script contained in the Fixlet stores this value in the ".results" file and the relevance reads it from there.

An SCM Applicability Fixlet consists of the following XML elements:

Title: This field typically contains a short description of endpoint attributes that this Fixlet will be relevant for i.e: Windows 2003, AIX 6.1, IIS is installed, ...

Description: : HTML markup that displays in the body of the Fixlet.

Relevance: This is a relevance statement that scopes Fixlets into a functional group, typically an operating system and version. i.e. 'Name of operating system = "SunOS 5.10"'

x-fixlet-sentinel-id: A string that uniquely identifies this applicability constraint/Fixlet. This is referenced by the x-fixlet-sentinel-idref field in the Fixlets that share this applicability constraint.

x-fixlet-scm-compatibility: Used by the Create Custom Checklist Wizard, this field controls which TEM external sites can be used together to create a single custom site. When creating custom content this is a no-op since it only applies to TEM "External" sites.

The x-fixlet-scm-metadata field in the Fixlet:

The x-fixlet-metadata MIME field in the fixlet contains data that is used exclusively by the TEMA reporting infrastructure. It is a JSON serialized data structure. This is where the Fixlet is associated with the Analysis for display in TEMA. A minimal x-fixlet-scm-metadata example is given below

```
<MIMEField>
      <Name>x-fixlet-scm-metadata</Name>
      <Value><![CDATA[___JSON_SERIALIZED_DATA_HERE___ ]]></Value>
</MIMEField>
```

and here is the minimal JSON structure:

```
{
   "title": "Fixlet title",
   "description": "fixlet description",
   "scm_parameters": {
      "Value": {
          "measured_value_analysis_idref": "pointer-to-my-analysis",
          "measured_value_analysis_property": 1
      }
   }
}
```

The JSON data structure consists of the following components:

title: The check title in TEMA, typically the same as the Fixlet "Name" field.

description: The check description in TEMA, typically the same as the Fixlet "Description" field.

measured_value_analysis_idref: This is a reference to the "x-fixlet-scm-analysis-id" value in the associated Analysis. TEMA uses this data to associate the Fixlet with its Analysis.

NOTE: There are many other possible entries in the JSON data structure. This is a minimal example only. If additional information is required please contact the TEM SCM development team.

Difference between Windows and Unix SCM Methods

While Windows SCM Fixlets are typically implemented exclusively in the Relevance(tm) language, UNIX SCM Fixlets that work with the supplied TEM infrastructure have a minor relevance component and a shell script component that does most of the work. This approach was taken because popular UNIX SCM benchmarks are specified in shell script (DISA,CIS,...) or other metadata that is readily translated to shell scripts and shell scripts can take advantage of the output of common *NIX utilities specified by benchmark authors.

Writing UNIX SCM Audit scripts

TEM Unix SCM provides a framework which minimizes the labor necessary to incorporate new checks.

The major functional part of a UNIX SCM Fixlet is a Bourne shell script. There are very few constraints on the content of the scripts other than they must populate two environment variables: RESULT which must be the string "PASS" or "FAIL" where FAIL means that the check detected non-compliance and REASON which is what TEMA will use as the "measured value" of the check.

These shell scripts must be base64 encoded and if the size of the encoded file is > 2800 bytes the script must be broken down into chunks. These chunks are then put into MIME fields of the fixlet:

Remediation scripts "*.remediate" follow the same encoding guidelines but are not required to populate any environment variables.

```
<MIMEField>
      <Name>x-fixlet-detect-script0</Name>
      <Value>MY_CHECK.detect:IyEvYmluL3NoCgpTQ1JJUFRMRVRfU1RBUlRf...</Value>
</MIMEField>
<MIMEField>
      <Name>x-fixlet-detect-script1</Name>
      <Value>MY_CHECK.detect:IyEvYmluL3NoCgpTQ1JJUFRMRVRfU1RBUlRf...</Value>
</MIMEField>
```

Where MY_CHECK is the SourceID of the Fixlet and will be used as the script basename.

A sample script is shown on the next page:

```
#!/bin/sh

# start required preamble

SCRIPTLET_START_TIME=`./util/get_epoch_seconds`

ME=`basename $0 .detect`

LOG_DIR=${BFTMPDIR}/results

RESULTS_FILE=${LOG_DIR}/${ME}.results

TMPFILE=${BFTMPDIR}/tmp/${ME}.tmp.$$

>$TMPFILE

. ./util/getparams

# this is the part that contains the audit logic:

# you must populate RESULT with either PASS or FAIL

# you should populate REASON with an explanation

RESULT=PASS

REASON="/something.bad is not readable"

if [ -r /something.bad ]

then

       RESULT=FAIL

       REASON=`ls -ld /something.bad`

fi

# this ends the audit logic, the following call to logmodule is required

. ./util/logmodule

#EOF
```

Here is the XML for a minimal UNIX SCM Fixlet:

Working TEM deployment

<li>License for TEM SCM content

<li>Working TEM SCA deployment<?xml version="1.0" encoding="UTF-8"?>


```
<BES xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xsi:noNamespaceSchemaLocation="BES.xsd">

  <Fixlet>

    <Title>File check - /something.bad</Title>

    <Description><![CDATA[Audit: See if /something.bad exists<p>Remediation: Remove /something.bad]]></Description>

    <Relevance><![CDATA[name of operating system = "AIX 6.1" AND version of client >= "8.1.551.0"]]></Relevance>

    <Relevance><![CDATA[line ((line number of it + 1 ) of lines whose (it contains "[STATUS]") of file "MYCHECK-1.1.results" of folders ( (  ( pathname of client folder of current site) ) &
"/SCM/mytmp/results")) of file "MYCHECK-1.1.results" of folders ( (  ( pathname of client folder of current site) ) & "/SCM/mytmp/results") = "FAIL"]]></Relevance>

    <Category>File Checks</Category>

    <Source>MYCUSTOMER AIX 6.1 Version 1.0.0</Source>

   <SourceID>MYCHECK-1.1</SourceID>

    <SourceReleaseDate>2012-02-21</SourceReleaseDate>

    <SourceSeverity>Level_2</SourceSeverity>

    <MIMEField>

      <Name>x-fixlet-scm-metadata</Name>

      <Value><![CDATA[{"title": "File check - /something.bad","description": "Audit: See if /something.bad exists<p>Remediation: Remove /something.bad","scm_parameters": {"Value":
{"measured_value_analysis_idref": "pointer-to-my-analysis","measured_value_analysis_property": 1}}}]]></Value>

    </MIMEField>

    <MIMEField>

      <Name>x-fixlet-scm-sentinel-idref</Name>

      <Value> cpe:/o:ibm:aix:6.1</Value>

    </MIMEField>

    <MIMEField>

      <Name>x-fixlet-scm-id</Name>

      <Value>MYCHECK-1.1</Value>

    </MIMEField>

    <MIMEField>

      <Name>x-fixlet-scm-category</Name>

      <Value>File Checks</Value>

    </MIMEField>

    <MIMEField>

      <Name>x-fixlet-scm-os</Name>

      <Value>AIX 61</Value>

    </MIMEField>

    <MIMEField>

      <Name>x-fixlet-detect-script0</Name>

      <Value>MYCHECK-1.1.detect:IyEvYmluL3NoCgpTQlJJUFRMRVRfU1RBU1Rf...</Value>

    </MIMEField>
```

```
    <MIMEField>
      <Name>x-fixlet-detect-script1</Name>
      <Value>MYCHECK-1.1.detect:IyEvYmluL3NoCgpTQ1JJUFRMRVRfU1RBU1Rf...</Value>
    </MIMEField>
    <MIMEField>
      <Name>x-fixlet-remediate-script0</Name>
      <Value>MYCHECK-1.1.remediate:IyEvYmluL3NoIC14CgpTQ1JJUFRMRVRfU1RBU1RfVE1N</Value>
    </MIMEField>


    <Action ID="Action1">
      <Description>
      <PreLink>Click </PreLink>
      <Link>here</Link>
      <PostLink> to remediate this issue.</PostLink>
      </Description>
      <ActionScript MIMEType="application/x-Fixlet-Windows-Shell">wait /bin/sh -c "cd SCM; ./runme.sh -r MYCHECK-1.1"</ActionScript>
    </Action>
  </Fixlet>
</BES>
```

Here is the XML for a minimal UNIX SCM Analysis:

```
<?xml version="1.0" encoding="UTF-8"?>

<BES xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xsi:noNamespaceSchemaLocation="BES.xsd">

    <Analysis>

        <Title>MYCHECK-1.1 : File Check - /something.bad</Title>

        <Description><![CDATA[This is the analysis for MYCHECK-1.1]]></TABLE>

]]></Description>

        <Relevance>(name of operating system = "AIX 6.1" )</Relevance>

        <MIMEField>

            <Name>x-fixlet-scm-analysis-id</Name>

            <Value>pointer-to-my-analysis</Value>

        </MIMEField>

        <MIMEField>

            <Name>x-fixlet-scm-metadata</Name>


<Value>{"scm_parameters":{"properties":{"1":{"type":"string","description":""}}}}</Value>

        </MIMEField>

        <Property Name="File Check - /something.bad" ID="1" EvaluationPeriod="PT12H"><![CDATA[if
(exists file "MYCHECK-1.1.results" of folders ((pathname of parent folder of parent folder of
folder (pathname of client folder of current site)) & "/SCM/mytmp/results")) then (substrings
separated by "%0a" of (if (exists first "%0a[REASON_EOF]" of it) then (preceding text of first
"%0a[REASON_EOF]" of it) else nothing) of following text of first "[REASON]%0a" of concatenation
"%0a" of lines of file "MYCHECK-1.1.results" of folders ((pathname of parent folder of parent
folder of folder (pathname of client folder of current site)) & "/SCM/mytmp/results")) else "Not
Reported" ]]></Property>

    </Analysis>

</BES>
```

Here is the XML for a minimal UNIX SCM Applicability Fixlet:

```
<?xml version="1.0" encoding="UTF-8"?>

<BES xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xsi:noNamespaceSchemaLocation="BES.xsd">

    <Fixlet>

        <Title>Applicability Fixlet - IBM AIX 6.1</Title>

        <Description><![CDATA[<div class=FixletMessage><TABLE><TBODY><TR><TD>Applicability Fixlet
for IBM AIX-6.1</TD></TR></TBODY></TABLE></div>]]></Description>

        <Relevance>name of operating system = "AIX 6.1"</Relevance>

        <Category>Applicability Fixlet</Category>

        <MIMEField>

            <Name>x-fixlet-scm-sentinel-id</Name>

            <Value>cpe:/o:ibm:aix:6.1</Value>

        </MIMEField>

          <MIMEField>
                      <Name>x-fixlet-scm-compatibility</Name>
                      <Value> disa-aix6.1</Value>
                </MIMEField>

    </Fixlet>

</BES>
```